# Personal Information Protection Standard

Nunoli Soluções Digitais Ltda (Pólia One) · Brazil
Version 1.0 · Effective October 27, 2026 · Approved by Silvia Nunes de Oliveira, Managing Partner and Data Protection Officer
Complements the Information Security and Data Protection Policy v1.0 (October 23, 2026)

---

## 1. Purpose and scope

This standard sets the mandatory rules for how Pólia One collects, uses, stores, shares and deletes personal information. It covers personal information of Pólia One users (sellers) and any personal information received from sales channels connected by those users, including TikTok Shop. It applies to all Pólia systems, to the people who operate them and to every sub-processor. It follows the Brazilian General Data Protection Law (LGPD, Law 13,709/2018) and the TikTok Shop Partner data requirements.

## 2. Roles and accountability

- **Data Protection Officer (DPO):** Silvia Nunes de Oliveira, privacidade@usepolia.com.br. Owns this standard, approves any new use of personal information, handles data subject and partner requests, and leads breach response.
- **Controller and processor:** Pólia is the controller of sellers' account data. For data received from TikTok Shop on a seller's behalf, Pólia acts as a processor and uses it only to deliver the service the seller enabled.
- **Anyone with access** signs a confidentiality agreement before first access, follows this standard and reports any suspected incident to the DPO immediately.

## 3. Principles

1. **Purpose limitation:** personal information is used only for the purpose stated in section 4.
2. **Minimization:** only the fields needed for that purpose are stored; everything else is discarded.
3. **Transparency:** the public privacy policy (usepolia.com.br/privacidade) describes every use.
4. **Security:** encryption in transit and at rest, least-privilege access, no secrets in code (section 6).
5. **Limited retention:** data is deleted when its purpose ends (section 7).
6. **Accountability:** every rule here is enforced in code or in a documented process, and checked (Appendix A).

## 4. Inventory: TikTok Shop data and why it is used

| Authorized scope | What Pólia reads | Purpose | What is stored |
|---|---|---|---|
| Shop Authorized Information, Global Shop Information | Shop ID, shop name, region, shop cipher | Identify which shop belongs to which seller account | Shop ID, name, region, cipher |
| Product Basic | Product and SKU IDs, titles, seller SKU codes | Let the seller link each listing to a product in Pólia One | Product ID, SKU ID and the link to the seller's own product |
| Product Modify | (write only) available stock per SKU | Update listing stock when the seller turns on stock sync | Nothing additional |
| Order Information | Order ID, status, paid time, line items (SKU, name, quantity, price after seller discount) | Record the sale, move stock and calculate the TikTok fee for the seller | Order ID, date, items, quantities, prices, calculated fee |
| Finance Information | Not called in the current release | Reserved for future fee reconciliation | Nothing |

**Buyer personal information is not stored.** Order payloads are processed in memory; the buyer's name, address, phone number, email and any other buyer identifier are discarded and never written to the database, to logs or to backups. Pólia does not use TikTok Shop data for advertising, profiling, model training or contacting buyers, does not sell or share it, and does not combine it with data from other sources about the same buyer.

## 5. Seller (user) personal information

- Collected: name, email, login data, business information the seller types in, subscription and payment status (card data is handled only by Stripe and never reaches Pólia).
- Legal basis (LGPD art. 7): performance of the contract with the seller; legal obligation for tax records; consent for optional marketing email, which can be withdrawn at any time.

## 6. Security controls applied to personal information

- **Encryption:** TLS on every connection; database encrypted at rest (AES-256, Supabase managed PostgreSQL); TikTok Shop access and refresh tokens stored in Supabase Vault, encrypted and readable only by server-side code.
- **Isolation:** row-level security is enabled on every table. Tables holding TikTok Shop connection, events, listing links and sync queues allow no access from the browser at all: only server-side processes can read them.
- **Least privilege:** production access limited to the DPO, with multi-factor authentication on every administrative account; no shared accounts.
- **Integrity of incoming data:** TikTok Shop webhooks are accepted only with a valid HMAC signature; a shop is linked to an account only after the seller confirms it on screen.
- **Logs:** errors are logged without personal information or tokens.
- **Development:** every release passes a security checklist; database security advisors are checked after each schema change; a dedicated security review of the TikTok Shop integration was completed on October 24, 2026, before release.

## 7. Retention and deletion

| Data | Retention | How it is deleted |
|---|---|---|
| TikTok Shop access and refresh tokens | While the shop is connected | Deleted immediately on disconnection (Vault secrets removed by database trigger) |
| Shop connection and listing links | While the shop is connected | Deleted immediately on disconnection |
| Webhook event records (order ID only) | 7 days | Automatic daily cleanup job |
| Sales recorded from orders (no buyer data) | While the seller account exists; up to 5 years when tax law requires | Deleted with the account, or on seller request |
| Seller account and all its data | While the account exists | Seller deletes it in the product (Settings, delete account); all rows are removed by cascade |
| Any remaining TikTok Shop data after the partnership ends | Up to 30 days | Deleted by the DPO, except records required by law |

## 8. Data subject and partner requests

- Rights under LGPD art. 18 (confirmation, access, correction, deletion, portability, information about sharing, withdrawal of consent) are handled through privacidade@usepolia.com.br within 15 days.
- Requests from TikTok Shop or from a seller to delete, update or provide data received from TikTok Shop are handled through the same channel, with the same deadline. The seller can also disconnect the shop in Pólia One or revoke authorization in TikTok Shop Seller Center at any time.
- The requester's identity is verified before data is provided or deleted.

## 9. Sharing, sub-processors and international transfer

- Sub-processors: Supabase (database, United States, us-east-2), Cloudflare (application hosting), Stripe (payments), Resend (transactional email), Google (Analytics, Calendar and Gemini, for seller-provided data only). TikTok Shop data is processed only by Supabase and Cloudflare.
- Each sub-processor is bound by a data processing agreement. A new sub-processor requires DPO approval and an update to the privacy policy before it receives any data.
- Transfer to the United States relies on the safeguards of LGPD art. 33 (contractual clauses in the providers' data processing agreements).

## 10. Breach notification

1. Contain: revoke affected tokens and keys, block access, fix the cause.
2. Assess: which data, whose, how much and for how long.
3. Notify affected sellers and TikTok Shop by email within **48 hours** of a suspected or confirmed breach involving TikTok Shop data; notify data subjects and the ANPD when there is relevant risk or harm (LGPD art. 48).
4. Record the incident, root cause and corrective actions.

## 11. Awareness and review

Anyone granted access reads this standard and the security policy before first access and again after every update. The standard is reviewed at least once a year, and earlier when the law changes, a new data type or sub-processor is added, or an incident occurs.

| Version | Date | Change |
|---|---|---|
| 1.0 | October 27, 2026 | First version |

---

Approved by Silvia Nunes de Oliveira, Managing Partner and Data Protection Officer
Nunoli Soluções Digitais Ltda · privacidade@usepolia.com.br · October 27, 2026

## Appendix A. Evidence (checked in production on October 27, 2026)

| Control | Evidence |
|---|---|
| Row-level security on every table | 107 of 107 tables in the application database have row-level security enabled. |
| TikTok Shop tables are server-only | canal_conexoes, canal_eventos, anuncio_vinculos, canal_fila_estoque and canal_sync_travas: row-level security enabled with no access policy, so no browser session can read or write them. |
| Seller data scoped to the owner | Sales and fee tables allow read and update only where user_id equals the authenticated user. |
| Tokens encrypted | The connection table holds only references (access_secret_id, refresh_secret_id) to Supabase Vault secrets; tokens are never stored in plain columns. |
| No buyer data | The sale stored from a TikTok order contains: order ID, date, items, quantities, prices, fee and the note "Order [ID] from TikTok Shop". No buyer field exists in the schema. |
| Deletion on disconnection | Disconnecting deletes the connection row (a trigger removes the Vault secrets) and all listing links for that channel. |
| Automatic cleanup | Scheduled job "limpar-canal-eventos" runs daily and removes webhook event records older than 7 days. |
| Webhook authenticity | Incoming TikTok Shop webhooks are rejected unless the HMAC signature matches the app secret. |
| Account self-deletion | Available to every seller in Settings; user-linked tables reference the account with ON DELETE CASCADE. |

## Appendix B. Where each "Yes" answer of the questionnaire is supported

| Questionnaire topic | Section |
|---|---|
| Information security policy or program | Security Policy v1.0; this standard, section 6 |
| Network segregation and threat protection | Security Policy section 7; this standard, section 6 |
| Endpoint antivirus and security baseline (screen lock, passwords, clean desk, MFA) | Security Policy section 6; this standard, section 6 |
| Access control and least privilege | Section 6; Appendix A |
| Data classification and encryption in transit and at rest | Security Policy section 3; this standard, section 6 |
| Incident response policy | Section 10; Security Policy section 11 |
| Vulnerability management | Section 6; Security Policy section 9 |
| Internal data protection policy, regularly updated | This standard (sections 1 to 11, annual review) |
| Helping sellers and TikTok Shop delete, update or provide data | Section 8 |
| Privacy policy, regularly updated | usepolia.com.br/privacidade; section 3 |
| Data Protection Officer | Section 2 |
| Breach notification to TikTok Shop and sellers | Section 10 (48 hours) |
| Deletion at the end of the relationship | Section 7 |